



TECHNICAL ARCHITECTURE · V0.1

Sorted, end-to- end.

A peer-to-peer payments app for Australians, built on AUDD and Solana. This document describes the system, the partners, the responsibilities, and the path to launch.

What's inside.

01	Executive summary
02	Product context
03	By the numbers
04	System architecture
05	The third-party stack
06	Responsibility map
07	Core data model
08	Send transaction flow
09	Onboarding & KYC flow
10	Security model
11	Compliance posture
12	Build phasing
13	What we're watching
14	Open questions
15	Appendix • Tech stack & decisions

01

EXECUTIVE SUMMARY

Sorted, in one read.

The shape of the product, the rails it runs on, and why this architecture is the right one for a small team building a regulated financial product in Australia.

What we're building

Sorted is a peer-to-peer payments app for Australians, built on the AUDD stablecoin and the Solana settlement layer. It replaces 1–3 day BSB transfers with sub-2-second sends to memorable @handles, costs nothing per transaction, and pays daily yield on idle balances drawn from a tier-1 reserve.

The product looks and behaves like Cash App or Revolut — Australian users will not see crypto, wallets, seed phrases, or any blockchain-native concept. Sorted does that work in the background.

Send to any @handle, anywhere in Australia. Free. Instant. Done.

SORTED, IN ONE LINE

How we're building it

The architecture is intentionally conservative. We use a managed-service-first stack — Privy for embedded wallets, Frankie One for KYC, Helius for Solana RPC, Novatti for AUDD issuance — rather than rolling these capabilities ourselves.

This is the right call for a regulated financial product in Australia: it shortens our attack surface, narrows our compliance scope, and lets a small team ship safely.

THE POSITION

We are not custodial. User funds are held in non-custodial wallets generated and managed by Privy (TEE-based key management), backed 1:1 by AUDD issued by Novatti against AUD reserves at tier-1 Australian banks. Sorted's role is the user-facing product, the orchestration layer, and the books — not the value custody.

02

PRODUCT CONTEXT

Who it's for, what it does.

The product hits a clear gap — fast peer payments for Australians without the BSB friction or the crypto baggage.

The core promise

\$0

PER TRANSACTION

No transaction fees, no FX margin, no card fees.

Revenue comes from the spread on idle reserves.

< 2_{sec}

TAP TO BALANCE

Solana settlement plus immediate UI confirmation.

Beats every Australian bank transfer.

3.33%

YIELD ON IDLE

Paid daily. No tier, no minimum, no lock-up.

Drawn from RBA cash rate on the reserve.

Who it's for

Adult Australian residents (18+) who hold an Australian-issued ID and an Australian bank account.

The launch cohort is a closed beta of 50–200 friends-of-the-team, expanding to public beta after the compliance and rails work completes.

What's in v0.1, what's out

In: Send/receive between users via @handle. Top-up via PayID. Cash-out via PayID. Yield on idle balance. Activity feed. KYC flow. Push notifications.

Out (planned post-launch): International sends. Debit card issuance. Business accounts. Investment products beyond the embedded yield. Tax reporting tooling. Referral programs.

03

BY THE NUMBERS

What v0.1 looks like.

Honest projections. Beta cohort sized for a solo team to support directly. Limits set conservatively, with room to lift as KYC tier increases.

v0.1 closed beta

200

BETA CAP

Friends-of-the-team max.
Sized for one person to
support directly via inbox.

4_{wks}

TO BETA-READY

Pure dev work. Devnet with
mock AUDD. Compliance
runs in parallel.

~10_{wks}

TO LAUNCH

Wall-clock including
compliance, audit, and App
Store review.

Tier 1 KYC limits

\$1k

PER DAY

Send limit at Tier 1 (basic
KYC).

\$5k

PER MONTH

Rolling 30-day window.

\$10k

BALANCE CAP

Total AUDD held at any
time.

The third parties

1

WALLET

Privy. Non-
custodial.

1

KYC

Frankie One.
Australian.

1

RPC

Helius. Solana
mainnet.

1

STABLECOIN

AUDD via
Novatti.

04

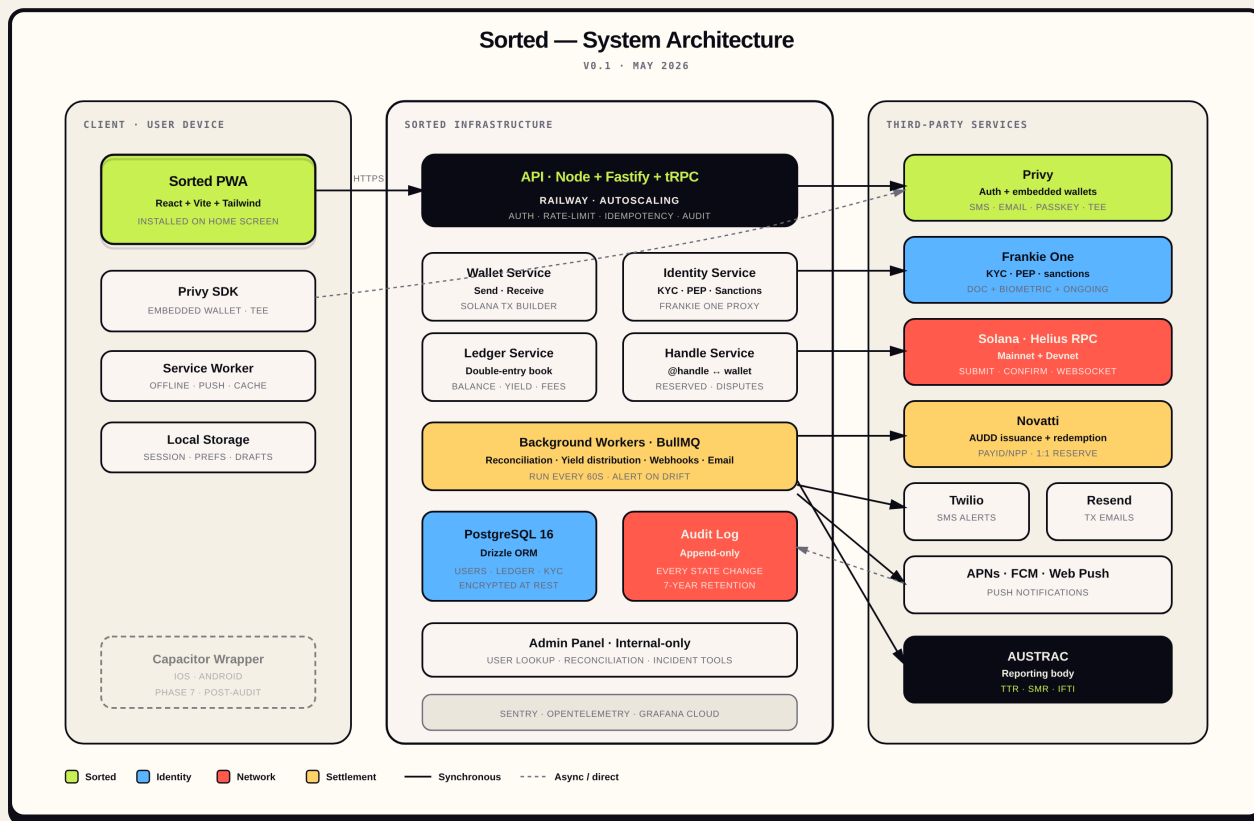
SYSTEM ARCHITECTURE

The shape of it.

A single Node monolith fronting Postgres. A thin React PWA client. Four critical third-party integrations. Boring, by design.

Three zones, four integrations

The system divides into three clear zones — the user's device, Sorted's infrastructure, and the third parties we lean on. The diagram below shows everything in one frame, with synchronous calls (solid arrows) and asynchronous flows (dashed) labelled.



SYSTEM ARCHITECTURE • V0.1

Why these choices

Node + TypeScript + Fastify + tRPC. TypeScript end-to-end (frontend and backend share types via tRPC) eliminates an entire class of bugs at the API boundary — critical when the API moves money. Fastify is faster than Express and has first-class schema validation.

PostgreSQL + Drizzle ORM. Postgres is the boring correct answer for any product handling money. Strong consistency, transactions, mature replication. Drizzle emits visible SQL — we never want a payments engineer to be unsure what query is running.

Why these choices, continued

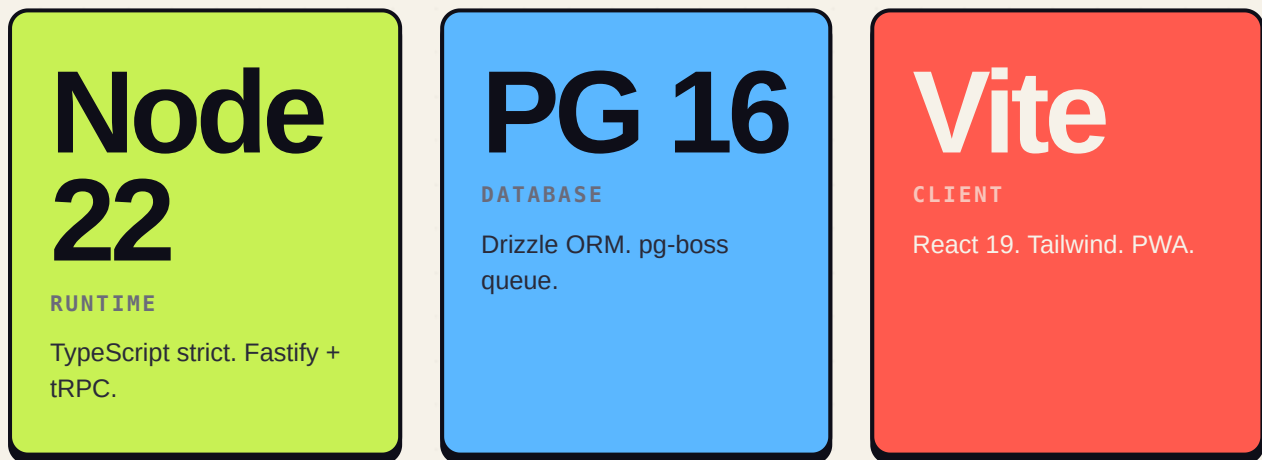
Monolith over microservices. A single solo engineer cannot operate microservices safely. The system can be split later when team size warrants it; doing so prematurely is a common failure mode and we are choosing not to make it.

Vercel for the PWA, Railway for the API. Vercel is the path of least resistance for static + edge deploys. Railway gives us managed Postgres + a long-running Node process + cron + secrets in one place.

THE PRINCIPLE

Every choice optimises for **velocity for one engineer, with safety**. We add complexity only when it earns its keep — never as a default.

The stack at a glance



05

THIRD-PARTY STACK

Who we lean on.

Five external services do the work we're not the experts on. Each named below with the function it performs and the risk it removes from us.

Privy · Authentication + wallets

Email + SMS + passkey login flows, wallet generation in a TEE (trusted execution environment), transaction signing, recovery via auth method. Users authenticate once with their phone or email; Privy handles the wallet lifecycle entirely client-side. Sorted never sees a private key.

WHY THIS MATTERS

Because we are not custodial user funds, Sorted's regulatory scope is narrower than a traditional payments app. The user holds their AUDD; we provide the interface. This is the cleanest position to take with the AFSL holder and AUSTRAC.

Frankie One · Identity

Australian document verification (driver's licence, Medicare, passport), biometric face match against the document, PEP/sanctions screening, suspicious matter flagging, ongoing screening for users post-onboarding. The standard for AU fintechs.

Helius · Solana RPC

Higher rate limits than public RPCs, websocket subscriptions for real-time tx confirmation, indexed transaction history APIs (replacement for parsing raw on-chain data ourselves). Without Helius, we'd be writing our own Solana indexer — a non-starter for v0.1.

Novatti - AUDD + reserves

A regulated Australian financial services provider that mints AUDD against AUD reserves held in tier-1 Australian banks. Novatti operates under their own AFSL and handles the bank-side reserve management. They expose APIs for triggering mint/burn operations and for orchestrating PayID transfers.

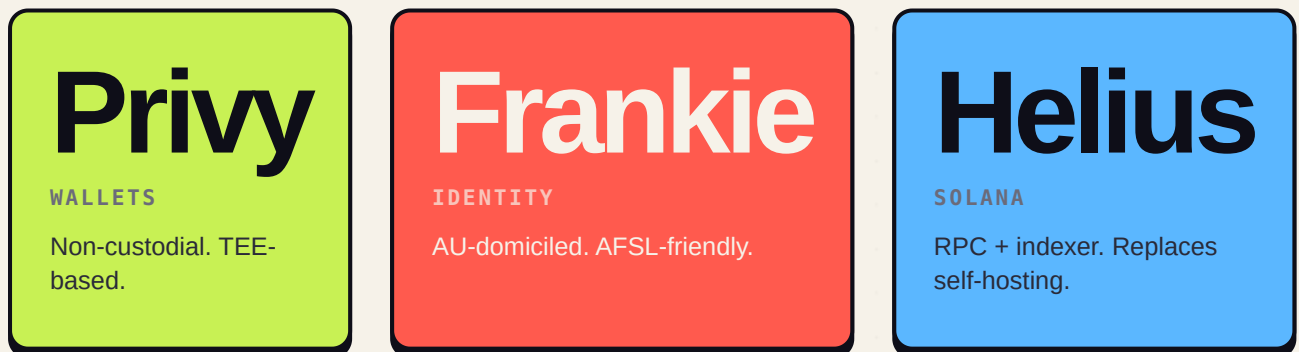
STATUS

Relationship under negotiation. The architecture in this document assumes the partnership completes; until then, the closed beta runs against Solana devnet with a mock AUDD token to prove the rails work.

Twilio + Resend + APNs/FCM

SMS for transaction alerts (Twilio), transactional email (Resend), and push notifications (APNs for iOS, FCM for Android, Web Push for the PWA). Standard infrastructure. Replaceable.

Five vendors, four functions

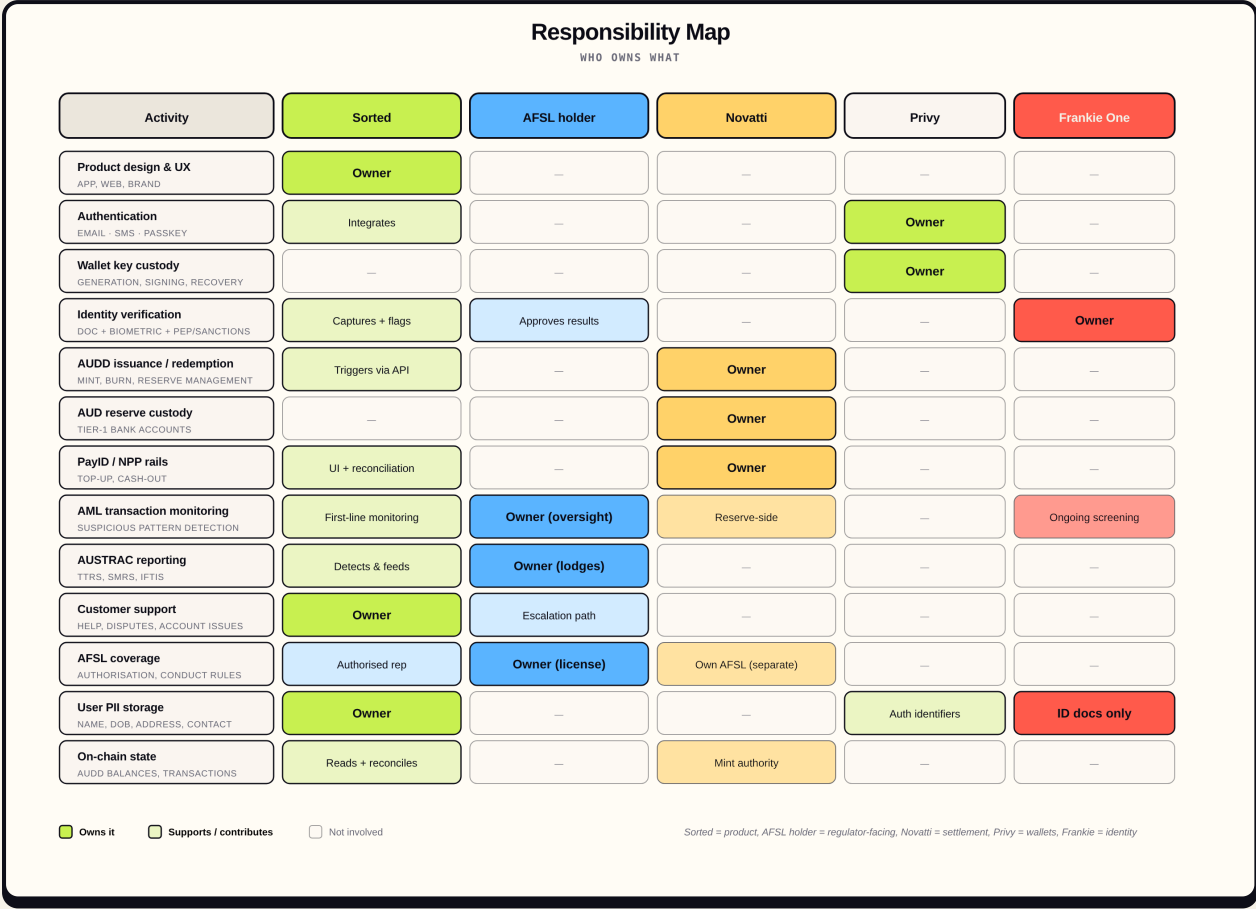


06

RESPONSIBILITY MAP

Who owns what.

The most important visual in this document for partner conversations. It answers, at a glance, what your exposure is if you partner with us.



RESPONSIBILITY MAP · 13 ACTIVITIES × 6 ENTITIES

The pattern

Sorted owns the product surface and the customer relationship. Regulated value-handling is owned by partners (Novatti for the reserves, Privy for keys, the AFSL holder for the licence). Compliance reporting is shared, with the AFSL holder having the lodgement authority.

Why this structure

This structure is deliberately chosen to match what AFSL holders typically require of authorised representatives in Australia, and to match Novatti's existing partner model. It also matches how AUSTRAC views designated remittance service providers operating under shared-licence arrangements.

The clean separation also has practical consequences. If Privy goes down, our database is intact and users can export their keys. If Novatti has a settlement issue, our books still tell us who owes what. If we have a bug, the partners' systems are insulated. Each layer fails independently.

Sorted holds the relationships. We connect a user (Frankie-verified) to a wallet (Privy-managed) to a balance (Novatti-issued AUDD). Each partner does what they do best.

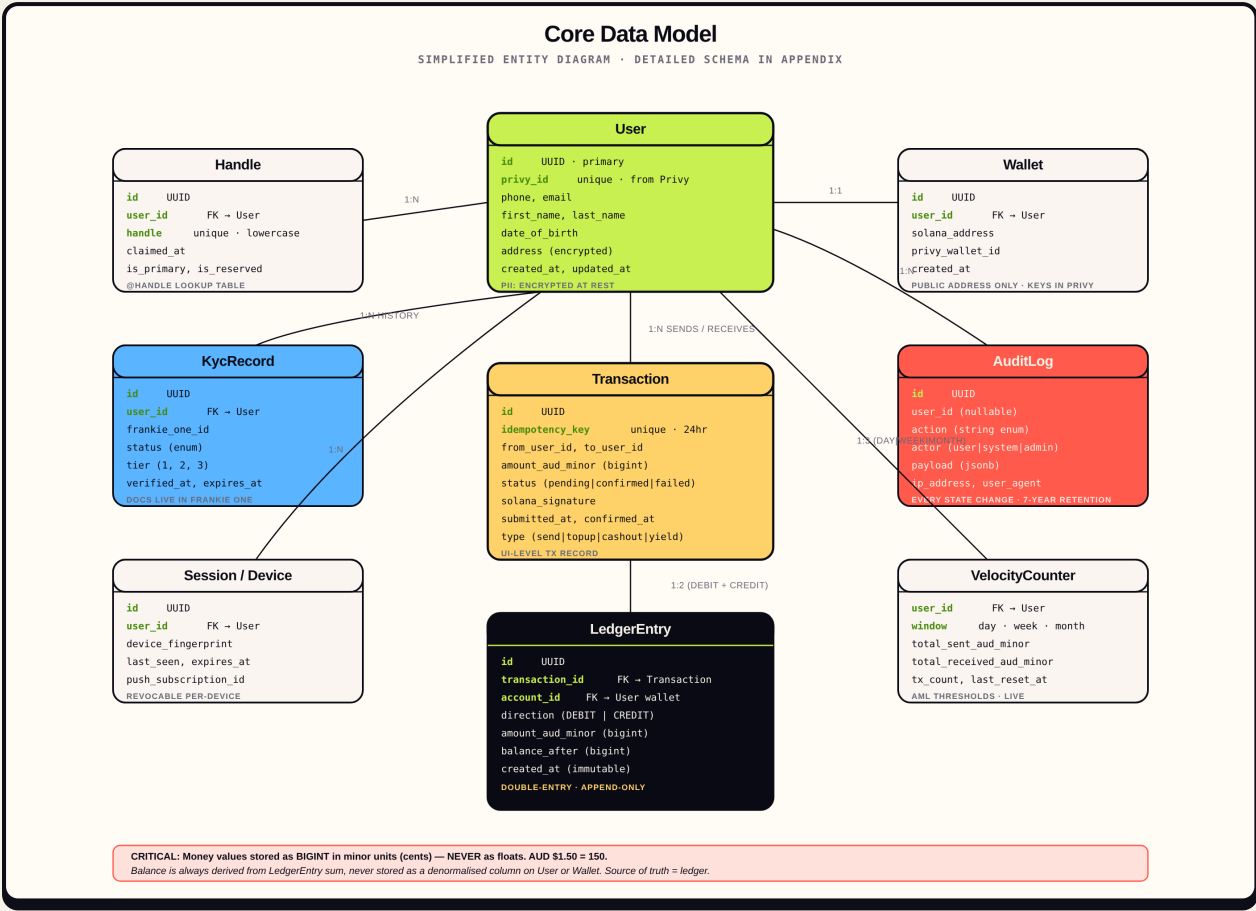
THE LINE, IN ONE SENTENCE

07

CORE DATA MODEL

The shape of the books.

Source of balance is the ledger, not a denormalised column. Money is BIGINT in cents, never floats. These are non-negotiable for a payments product.



CORE DATA MODEL · SIMPLIFIED ENTITY DIAGRAM

Eight tables, two of which carry the most weight: the **LedgerEntry** (append-only, double-entry) and the **AuditLog** (append-only, immutable). Everything else can be reconstructed from these two if it has to be.

Critical conventions

BIGINT

NEVER FLOAT

All money stored as integer cents. \$1.50 = 150. Eliminates rounding errors.

2 entries

PER TX

Every send creates a debit and a credit. Balance is SUM, never stored.

24 hr

IDEMPOTENCY TTL

Every state-changing endpoint requires an idempotency key. Double-tap protected.

7 yrs

AUDIT RETENTION

Append-only audit log. AUSTRAC requirement. Encrypted at rest.

PII HANDLING

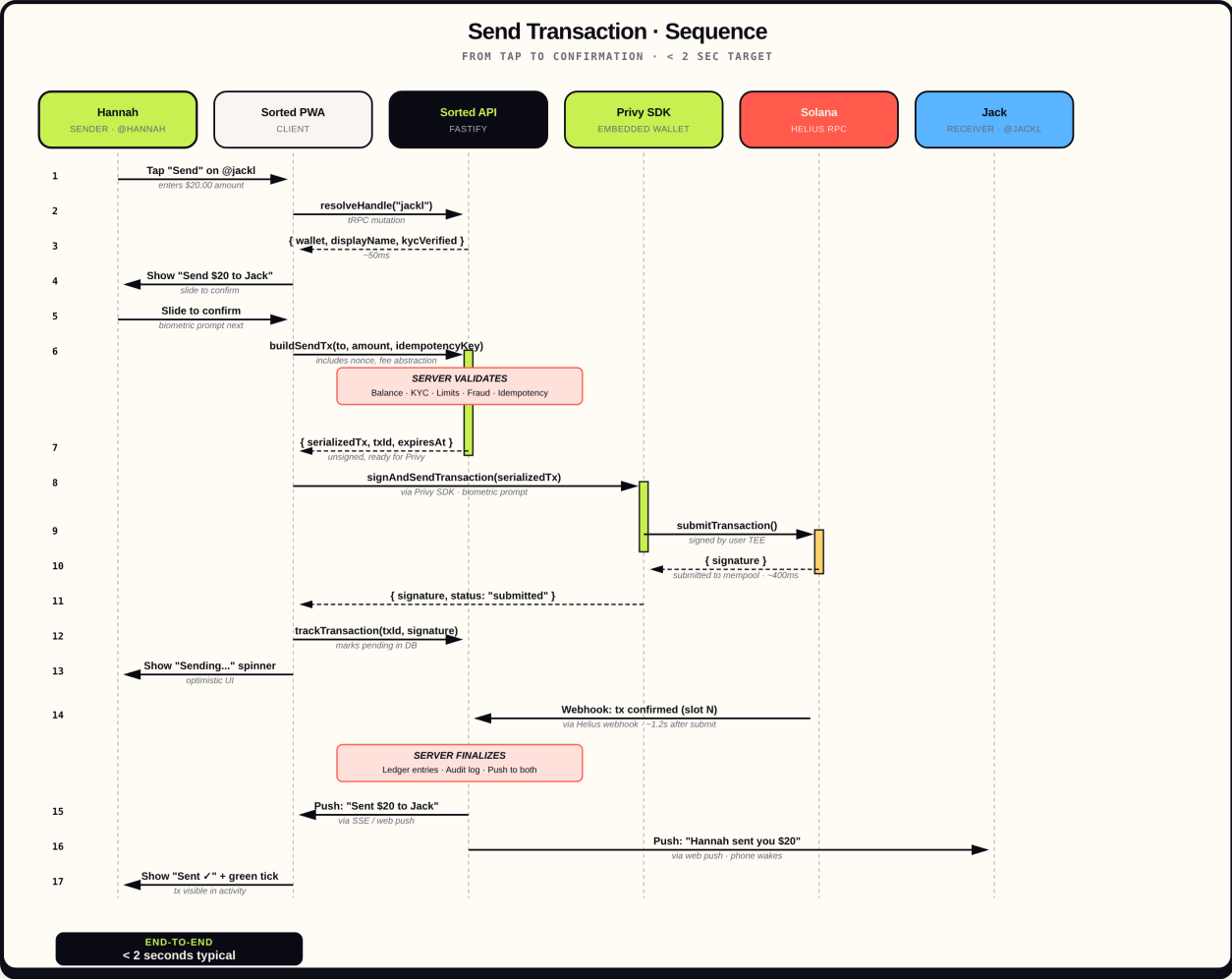
User PII is encrypted at rest with envelope encryption — column-level encryption keys are managed via a KMS, the master key never lives in the application. Logs are auto-redacted for PII fields. Identity documents are stored at Frankie One, not us — we hold a reference ID only.

08

SEND TRANSACTION

From tap to confirmed.

The most important interaction in the product. It must be fast (< 2 seconds end-to-end), atomic (no half-sends), and observable (every step logged for compliance).



What's noteworthy in this flow

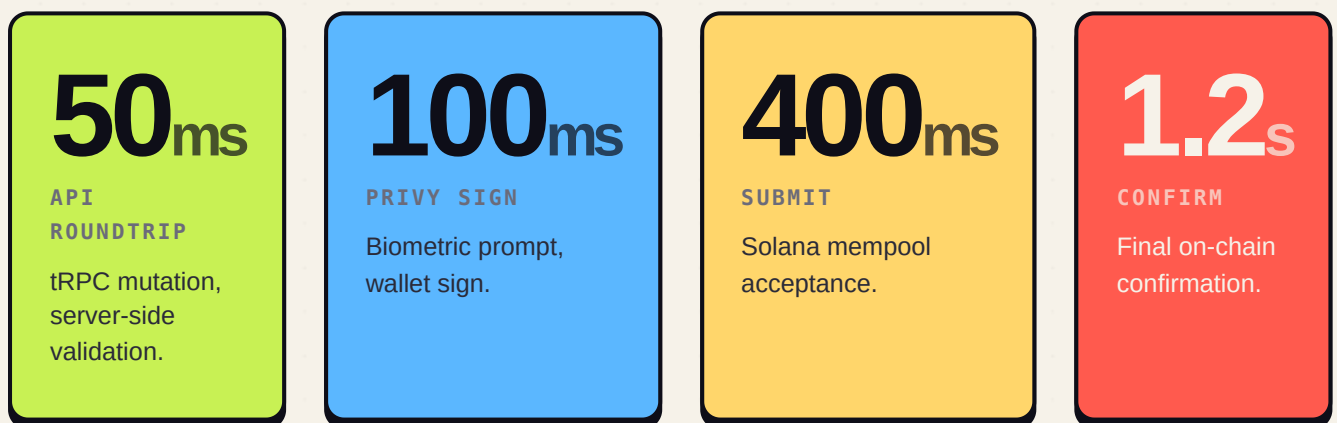
Server validates before signing. Balance, KYC tier, velocity limits, fraud signals, idempotency check — all happen server-side before we ever ask the user's wallet to sign anything. This means we cannot accidentally sign a transaction that violates a limit.

The user signs, not Sorted. The transaction is built server-side, serialised, sent to the client, and signed by the user's Privy embedded wallet. Sorted's backend never holds private keys.

Optimistic UI, eventual confirmation. The user sees "Sent" the moment Solana acknowledges submission (~400ms). Final confirmation comes via Helius webhook a second or so later, at which point we write the ledger entries and push notifications.

Reconciliation runs separately. A worker compares our database state against on-chain state every 60 seconds. Any drift triggers an alert and freezes affected accounts pending investigation.

Timing breakdown



09

ONBOARDING & KYC

Get to value, then verify.

The first experience matters enormously. Too much friction and the user bails before they fund the wallet. The flow is built to get the user to "wow" first, then gate at the right moments.

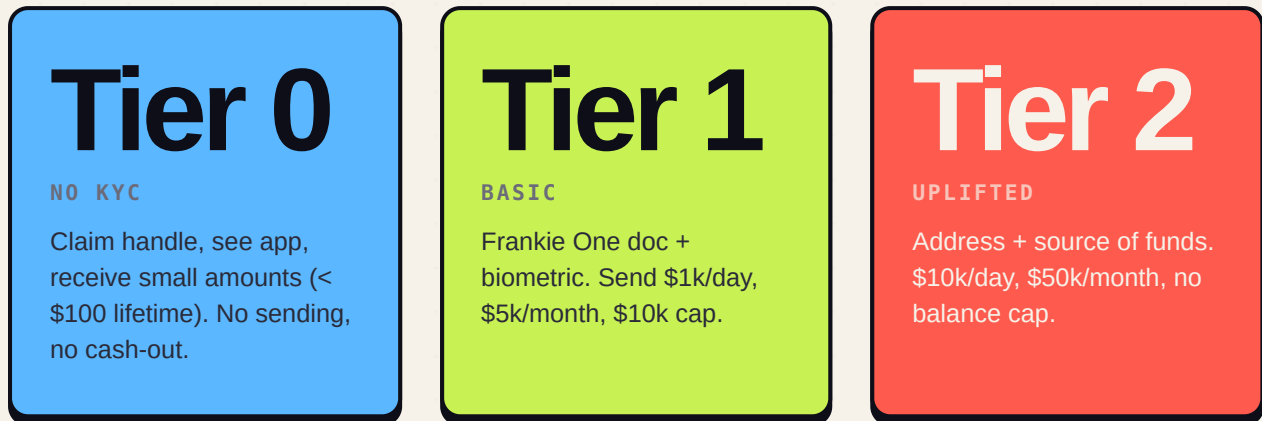
The flow, at a glance

1. **Sign in.** Privy phone/email OTP. ~30 seconds.
2. **Claim @handle.** 5 seconds. Sorted's killer onboarding moment.
3. **Wallet creation.** Invisible. Privy generates the embedded wallet in the background.
4. **Empty home screen.** "G'day, Hannah" with a clear "Verify to start sending" prompt.
5. **Verify identity.** Frankie One: 2-3 minutes for document scan + face match.
6. **Top-up via PayID.** Instant once user sends from their bank.

DEFERRED VERIFICATION

KYC is **deliberately deferred** until the user wants to do something that requires it. This lets users explore the app, claim a handle, and feel the product before we ask for their licence. Cash App and Revolut do the same — get to wow first, gate later.

KYC tiers



Why three tiers

Tier 0 lets the user feel the product before any friction. Tier 1 unlocks core functionality with the minimum AML burden — this is where most users settle. Tier 2 exists for the small minority who need higher limits, with the additional verification justifying the larger flows.

Tier transitions are non-blocking: a user can be at Tier 0 and request to verify, complete it in 2-3 minutes via Frankie One Smart UI, and be at Tier 1 immediately. No human review unless the document fails.

10

SECURITY

What protects what.

Privy handles auth and keys. We handle session, PII, and rate limits. Frankie handles documents. The blast radius of any single failure is small by design.

Authentication

Privy handles primary authentication. Users sign in with phone, email, or passkey. Sorted's backend trusts a Privy-issued JWT, validates it on every request, and binds the session to a device fingerprint stored in the Session table.

Sensitive actions (send > \$500, change handle, change recovery method, add a new device) require **step-up authentication** — a fresh biometric or passkey challenge. We do not let a stolen phone with the app already open drain the wallet.

Wallet security

Privy embedded wallets use TEE-based key management — the user's private key is generated in a hardware-backed secure enclave (or in Privy's HSM-backed iframe on devices without TEE) and never crosses an unencrypted channel. The user can export the key as a backup. Sorted has zero ability to sign on the user's behalf.

PII handling

User PII (name, DoB, address, phone, email) is stored in Postgres with column-level encryption using a KMS-managed envelope key. Identity documents are stored at Frankie One — we hold a reference ID but never the document itself. Logs are scrubbed at write time for PII patterns.

Rate limiting & fraud

Per-IP and per-user rate limits at the API layer. Velocity counters at the user level (sends per day/week/month) trigger AML review when crossed. New device + new geography + high-velocity pattern triggers a step-up auth challenge.

INCIDENT RESPONSE

A documented runbook covers: balance drift detected, unauthorised access detected, third-party outage, payment processor failure, mass-account compromise. The runbook lives in the same repo as the code so it stays current.

The security layers

TEE

KEY STORAGE

Hardware enclave on device. Sorted never sees keys.

JWT

AUTH

Privy-issued, device-bound, short-lived.

KMS

PII ENCRYPTION

Envelope encryption.
Master key never in app.

11

COMPLIANCE

Where we stand.

This is the section partners read most carefully. Honesty is the right policy. We're explicit about what we're doing, what we're not doing, and what we're not yet doing.

Where we stand

- **AFSL coverage:** Sorted will operate as an Authorised Representative under an existing AFSL holder. Conversations with potential AFSL hosts (including Australian exchanges) are in progress.
- **AUSTRAC enrolment:** We will enrol as a designated remittance service provider with AUSTRAC before mainnet launch. This is non-negotiable.
- **AML/CTF program:** A documented AML/CTF program covering customer identification, ongoing monitoring, suspicious matter reporting, threshold transaction reporting, and IFTI reporting will be in place before mainnet launch. Co-developed with the AFSL holder.
- **Privacy Act compliance:** Privacy policy, opt-in consent flows for marketing, and APP-compliant breach response.
- **Tax:** AUDD-to-AUDD sends are explicitly NOT capital gains events under current ATO guidance for AUD-pegged stablecoin transfers between domestic users — to be confirmed with our tax advisor and disclosed clearly to users.

WHAT WE EXPLICITLY ARE NOT CLAIMING

- We do **not** hold an AFSL.
- We are **not** a custodian.
- We do **not** hold AUD reserves directly (Novatti does).
- We are **not** a deposit-taking institution; AUDD balances are not bank deposits and are not protected by the Financial Claims Scheme.

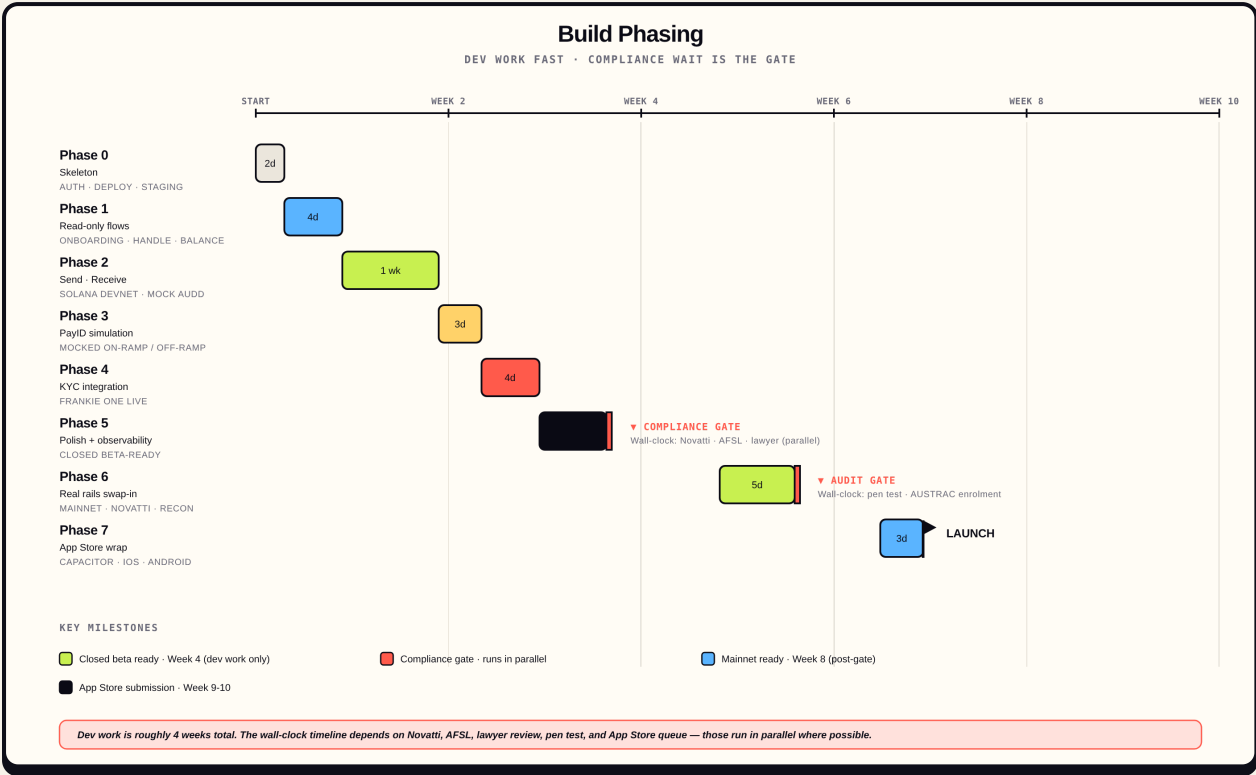
These boundaries are documented in the user agreement, the website, and the architecture itself.

12

BUILD PHASING

How it ships.

Seven phases. Roughly 4 weeks of dev work to closed-beta-ready, 9-10 weeks to launch. The wait isn't engineering — it's compliance gating.



BUILD PHASING • 7 PHASES • ~4 WEEKS DEV WORK

Engineering is roughly 4 weeks. The wall-clock timeline depends on Novatti, AFSL, lawyer review, pen test, and App Store queue — those run in parallel where possible. The diagram above shows it clearly: bars are the work, vertical red marks are the gates that aren't engineering.

Phases 0 — 5 · the build

Phase 0 — Skeleton (2 days). Privy auth working end-to-end against staging. Monorepo with PWA + API. Vercel and Railway pipelines. No business logic yet.

Phase 1 — Read-only flows (4 days). Onboarding through to "wallet ready" home screen. Handle claim integrated with the existing email-capture from the marketing site.

Phase 2 — Send/Receive on devnet (1 week). The meat of the build. Real Solana devnet transactions with mock AUDD. Idempotency, audit logging, double-entry ledger all working.

Phase 3 — PayID simulation (3 days). Top-up and cash-out flows. Mocked: a button in the admin panel that "credits" the user.

Phase 4 — KYC integration (4 days). Frankie One Smart UI integrated. KYC tier transitions. Velocity counters. Limits enforcement.

Phase 5 — Polish + observability (4 days). Empty states, error states, loading states everywhere. Admin panel for support. Structured logging. **At this point, the closed beta is ready — week 4.**

COMPLIANCE GATE · RUNS IN PARALLEL

Novatti relationship signed. AFSL holder relationship signed. Lawyer-reviewed user agreement and privacy policy. AUSTRAC enrolment lodged. **This is the wait, not the engineering.** The closed beta runs on devnet during this period — partners and friends can use it, just with mock tokens.

Phases 6 — 7 · launch

Phase 6 — Real rails swap-in (1 week). Mock AUDD replaced with real AUDD mint address. Novatti webhook integration. Real reconciliation against AUDD reserves. AUSTRAC reporting hooks.

AUDIT GATE · EXTERNAL WORK

Penetration test by a reputable security firm (~2 weeks external turnaround). Code review by a payments engineer outside the team. AUSTRAC enrolment confirmed.

Phase 7 — App Store wrap (3 days dev). Capacitor wrapper for iOS and Android. App Store Connect listing. Apple review queue is the wall-clock tail (~7-10 days). **Public launch.**

Total time, honestly

~4wks

TO CLOSED BETA

Pure dev time. Friends-of-team can use it on devnet with mock AUDD.

~4wks

DEV TO LAUNCH

Sum of all engineering phases. Compliance is parallel.

~10wks

WALL-CLOCK

Including Novatti / AFSL / pen test / App Store queue.

13

WHAT WE'RE WATCHING

Active mitigations.

The dependencies and decision points we're managing as the project progresses. Each has a clear path forward; none are blocking. Documented here so partners can see how we operate.

The items below are dependencies, decision points, or external timelines we're tracking. Each has an active mitigation already in place. Status updates monthly.

What we're watching	How we're managing it
Novatti partnership timeline	Architecture is designed to run on Solana devnet with mock AUDD indefinitely. The closed beta proceeds with friends-of-the-team during the partnership negotiation. Alternate AU-issued stablecoins (e.g. USDC via Circle) are kept in scope as a fallback option.
AFSL host selection	Multiple Authorised Representative conversations are in progress with Australian exchanges and adjacent licence holders. We're selecting the partner that best matches our model, not the first to commit.
Privy availability	Privy's TEE-based wallets are designed to be exportable — users retain access via export keys even in the unlikely event Privy is unreachable. Documented in the user agreement.
Solana network performance	Clear "network busy" UI for the user, exponential backoff on retries, reconciliation against partial state. Helius redundancy provides additional headroom on RPC throughput.

Continued

What we're watching	How we're managing it
Frankie One pass rates	We monitor pass rates per cohort and have an internal override flow (manual review by team) for clear false-rejects. Frankie One's AU-tuned pipeline gives us the highest baseline pass rate of any provider in market.
Compliance scope evolution	Our architecture is compliance-first. New AUSTRAC reporting requirements are mostly additive on top of what we already log. Scope changes typically translate to days of work, not weeks.
App Store review	Capacitor wrap is well-established for AU fintechs. We follow Apple's financial app guidelines (clear AFSL identification, ToS link, no misleading earnings claims). PWA-only fallback is always available on the open web.
Engineering capacity	Architecture is intentionally simple to enable handover and onboarding. We're hiring the next 1-2 engineers as funding allows, with a target of bringing them on before phase 6 (real rails swap-in).

WHY WE DOCUMENT THIS

Sophisticated partners look for evidence that a team understands its environment, not just its product. **Knowing what we're managing is itself a sign of operational maturity.**

14

OPEN QUESTIONS

What we don't yet know.

Listed here as a transparency signal. Partners should know what's still being decided, and so should anyone reading this for the first time.

Decisions still pending

1. **AFSL host identity.** Multiple conversations open. Final partner not chosen.
 2. **AUDD specifics.** Confirming with Novatti: minting cadence (real-time vs batched), redemption SLAs, fee structure for Sorted, branding constraints.
 3. **Limits.** \$1k/day at Tier 1 is a starting position. Final values set with AFSL holder.
 4. **Yield mechanics.** Pass-through model proposed (Sorted earns RBA cash rate on reserve, passes ~80% to user as 3.33% APY). Final spread negotiable with reserve bank.
 5. **Tax treatment.** Confirming with tax advisor that AUDD-to-AUDD sends are not CGT events for individuals. Disclosed to users either way.
 6. **Customer support tooling.** v0.1 is direct (founder's inbox). Tooling decision deferred to v0.2.
 7. **Referral mechanics.** Out of scope for v0.1 launch but desired for growth. Designed in v0.2.
-

We list these openly because partners want to see the analysis, not the spin. Knowing what you don't know is itself a sign of competence.

WHY THIS SECTION EXISTS

15

APPENDIX

Stack reference & decisions log.

The full technology choices and the meaningful decisions made during architecture, with the reasoning. So a future engineer understands not just what we chose, but why.

Technology stack

Client (PWA)

React 19, TypeScript (strict). Vite 5. Tailwind CSS with brand tokens encoded. React Router v7. Zustand for state. Framer Motion for interactions. react-hook-form + zod for validation. Lucide React for icons. vite-plugin-pwa for service worker and manifest. Privy React SDK. Frankie One Smart UI SDK. @solana/web3.js + @solana/spl-token.

API

Node.js 22 LTS, TypeScript (strict). Fastify 5. tRPC 11. Drizzle ORM. PostgreSQL 16. pg-boss (queue, v0.1). BullMQ + Redis (queue, v0.2+). Pino for structured logging. OpenTelemetry SDK.

Hosting & ops

Vercel (PWA). Railway (API + Postgres). Helius (Solana RPC). Sentry (errors). Grafana Cloud (metrics, traces). Resend (transactional email). Twilio (SMS). 1Password / Doppler (secrets). Cloudflare (DNS, edge protection).

Eventually (post-launch)

Capacitor (native wrap). Apple Push Notification service. Firebase Cloud Messaging. AppFlow or similar for native build pipeline.

Decisions log

The meaningful technical decisions made during architecture, with the reasoning. So a future engineer understands not just what we chose, but why.

Vite + React over Next.js for v0.1

App is fully behind auth, no SSR needed, faster dev loop, smaller bundle, simpler PWA setup. Migration to Next.js is mechanical when SSR/SEO surface is needed.

Monolith over microservices

Solo engineering. Microservices are an organisational pattern; without an organisation, they are pure overhead.

Postgres for everything

Including queues (via pg-boss) for v0.1. Adding Redis is a v0.2 decision based on observed throughput, not a default.

tRPC over REST

End-to-end type safety. The frontend cannot accidentally send a malformed payload — it won't compile. For a payments app, this matters.

Decisions, continued

Drizzle over Prisma

Drizzle emits visible SQL. Prisma's query engine adds a layer of opacity we don't want near the ledger.

Non-custodial via Privy

Cleaner regulatory posture. No private keys on Sorted servers means a different (and better) compliance scope. Aligns with the AUSTRAC view of digital currency exchange providers.

Solana over alternatives

Sub-second finality at fraction-of-a-cent fees. AUDD is already issued on Solana via Novatti. Match the rails to the issuer.

Frankie One over Sumsb / Onfido

Australian-domiciled, Australian-tuned document coverage, the standard for AU fintechs. Lower friction with the AFSL holder.

Closed beta on devnet over delayed launch

Building against mock AUDD on devnet lets us prove the rails work and gather user feedback before we have signed with Novatti. This is a deliberate choice to maintain momentum during the partnership negotiation.



END OF DOCUMENT · V0.1

Money, **sorted.**

Thanks for reading. If you'd like to discuss any of this further — partnership, technical detail, or the path to launch — get in touch.

sortedaud.app

MADE IN BRISBANE, QUEENSLAND

Sorted Pty Ltd

V0.1 · MAY 2026